

تم إعداد هذه الوثيقة بعنوان "الدليل الإرشادي لتقييم أثر حماية البيانات (DPIA)" بموجب قانون حماية البيانات الشخصية رقم (24) لعام 2023 الصادر بتاريخ 17 أيلول لعام 2023 والمنشور في الجريدة الرسمية العدد 5881.

** توضح هذه الوثيقة مبادئ توجيهية فقط ولا تعتبر كوثيقة أو استشارة قانونية وبذلك فإن الجهة المعنية غير ملزمة بالتقيد بما ورد في بنود هذه الوثيقة.
يتم مراجعة هذا الدليل من قبل مديرية حماية البيانات الشخصية وتحديثه وفقاً للحاجة أو أية تحديثات قد تطرأ على القانون والأنظمة والتعليمات الصادرة بمقتضاه.

الدليل الإرشادي لتقييم أثر حماية البيانات	
الهدف	إرشاد الجهات المعنية بكيفية إعداد تقييم أثر حماية البيانات وفقاً لأحكام قانون حماية البيانات الشخصية رقم (24) لعام 2023 وبالاتساق إلى أفضل الممارسات والمعايير العالمية.
النطاق	تستهدف هذه الإرشادات كافة الجهات المعنية بتطبيق قانون حماية البيانات الشخصية رقم (24) لسنة 2023 بالإضافة إلى الجهات المعنية بمعالجة البيانات الشخصية.

يكون للكلمات والعبارات التالية حيثما وردت في هذا الدليل المعاني المخصصة لها أدناه ما لم تدل القرينة على غير ذلك:

- **تقييم أثر حماية البيانات (Data Protection Impact Assessment):** عملية تحديد وتقييم المخاطر المحتملة نتيجة لمعالجة البيانات، وذلك لتحديد ما إذا كانت هنالك آثار سلبية من شأنها إحداث ضرر جسيم بالشخص المعني. يهدف إجراء هذا التقييم إلى ضمان الالتزام بأحكام قانون حماية البيانات الشخصية والأنظمة والتعليمات الصادرة بمقتضاه، والتأكد من مشروعية عملية معالجة البيانات، مع ضمان وجود التدابير الأمنية والتقنية والتنظيمية للحد من هذه المخاطر أو تقليلها.
- **الضرر الجسيم:** أي ضرر مادي أو غير مادي قد يؤدي إلى التمييز، أو سرقة الهوية، أو الإحتيال، أو الخسارة المالية، أو المساس بالسمعة، أو إنتهاك سرية ونزاهة البيانات الشخصية أو أي أثر اجتماعي أو اقتصادي قد يؤثر على ممارسة الأشخاص المعنيين لحقوقهم وحياتهم.
- **التدابير الأمنية:** مجموعة من الإجراءات التي يتم إتخاذها لضمان أمن وسلامة قواعد البيانات والأنظمة التي تعالج البيانات.
- **التدابير التقنية:** مجموعة من الإجراءات التي يتم إتخاذها لتأمين قواعد البيانات والأنظمة التي تعالجها ضد مخاطر إستعمالها أو من الوصول غير المشروع أو المصرح به.
- **التدابير التنظيمية:** مجموعة من الإجراءات التي يتم إتخاذها لتأمين قواعد البيانات والأنظمة التي تعالجها عبر وضع أطر تنظيمية للمؤسسات والمنظمات وسلوك العاملين فيها.

إستناداً إلى المادة (11) الفقرة (ب/2) من قانون حماية البيانات الشخصية، والتي تنص على "يتولى المراقب المهام والمسؤوليات التالية":

التأكد من إجراء التقييم والفحص الدوري لأنظمة قواعد البيانات وأنظمة معالجة البيانات وأنظمة المحافظة على أمن وسلامة وحماية البيانات بشكل دوري على أن يقوم بتوثيق نتائج التقييم وإصدار التوصيات اللازمة لحماية البيانات ومتابعة تنفيذ هذه التوصيات.

وعليه يُستخدم هذا التقييم لتحديد مستوى خطورة البيانات محل المعالجة، وتأثير مستوى الإخلال بأمن البيانات وسلامتها، ونوعها، واحتماليتها، إضافة إلى أثرها على حقوق الأشخاص المعنيين، وذلك لضمان اتخاذ التدابير الوقائية المناسبة.

متى يتعين إعداد تقييم أثر حماية البيانات (DPIA):

تقييم أثر حماية البيانات ليس إلزامياً لكل عملية معالجة، وإنما يُعتبر إلزامياً في الحالات التي ورد النص عليها في المادة (6) من تعليمات التدابير الأمنية والتقنية والتنظيمية والتي تنص على:

لتحديد مستوى خطورة البيانات محل المعالجة وتأثير مستوى الإخلال بأمن البيانات وسلامتها ونوعها وإحتماليتها إضافة إلى أثرها على حقوق الأشخاص المعنيين، يلتزم المسؤول بإعداد "تقييم أثر حماية البيانات (DPIA)" أثناء إجراءات المعالجة في أي من الحالتين التاليتين:

1. معالجة البيانات الشخصية الحساسة أو نقلها الى خارج المملكة.
2. أي حالة أخرى يقرر المجلس إلزام المسؤول بإعداد "تقييم أثر حماية البيانات" لأجلها.

تجدر الإشارة إلى أن اجراء تقييم أثر حماية البيانات يتم قبل البدء بعملية معالجة البيانات الشخصية وعند استخدام طرق جديدة للمعالجة أو إجراء تغيير جذري على نشاط المعالجة الحالي، كما يجب شمول أي إجراءات للتخفيف من المخاطر في خطة المشروع لضمان تطبيق هذه الإجراءات.

الهدف من إعداد تقييم أثر حماية البيانات (DPIA):

1. ضمان الالتزام بأحكام قانون حماية البيانات الشخصية رقم (24) لعام (2023) والأنظمة والتعليمات الصادرة بمقتضاه.
2. التأكد من قانونية ومشروعية معالجة البيانات الشخصية.
3. حماية حقوق الأشخاص المعنيين وضمان عدم تعرضهم لأي مخاطر تمس حقوقهم، إستناداً إلى أحكام المادة (4) من قانون حماية البيانات الشخصية رقم (24) لعام (2023).
4. تمكين الجهة من تطبيق مبدأ "Privacy By Design And By Default".
5. التأكد من إتخاذ التدابير الأمنية والتقنية والتنظيمية المناسبة عند معالجة البيانات الشخصية.
6. الحد من المخاطر المرتبطة بحماية البيانات الشخصية والتقليل منها.
7. تعزيز مبادئ الشفافية والمساءلة في جميع عمليات معالجة البيانات الشخصية.

الخطوات المتبعة عند إعداد تقييم أثر حماية البيانات (DPIA)

يتم إعداد تقييم أثر حماية البيانات (DPIA) قبل البدء بعملية المعالجة. يشمل التقييم ما يلي:

1.	معلومات المسؤول	- معلومات المسؤول. - معلومات مراقب حماية البيانات الشخصية.
2.	تحديد الحاجة لإجراء تقييم أثر حماية البيانات	- توضيح الحاجة إلى ضرورة إجراء هذا التقييم. - توضيح أنواع المعالجة التي سيتم استخدامها لتحقيق الأغراض المطلوبة.
3.	وصف المعالجة والغرض منها	- توضيح طبيعة المعالجة. - تحديد نطاق المعالجة. - وصف واضح لسياق المعالجة. - وصف أغراض المعالجة والهدف منها. - توضيح كيفية إجراء عملية جمع البيانات وتخزينها وحذفها. - وصف واضح عن عملية نقل البيانات.
4.	الإستشارات	- توضيح كيف ومتى سيتم طلب آراء الخبراء في مجال أمن المعلومات. - تحديد الأفراد الذين سيتم إشراكهم في عملية الإستشارة. - توضيح هل سيتم طلب الإستشارة من معالجي البيانات من داخل الجهة.
5.	وصف إجراءات الإلتزام بأحكام قانون حماية البيانات الشخصية	- توضيح الأساس القانوني لعملية المعالجة. - هل تحقق المعالجة الغرض الذي جمعت من أجله البيانات. - هل هناك طرق أخرى لتحقيق نفس الغرض. - كيف يتم منع تضارب المهام والأدوار الوظيفية. - كيف سيتم الإلتزام بمبدأ جودة البيانات وتقليلها للحد الأدنى. - مدة تخزين البيانات. - المعلومات التي سيتم تقديمها للأشخاص المعنيين. - كيف سيتم تمكين الأشخاص المعنيين من ممارسة حقوقهم وفقاً لأحكام قانون حماية البيانات الشخصية. - ماهي الإجراءات التي إتخذت لضمان إلتزام معالجي البيانات لقانون حماية البيانات الشخصية. - كيف يتم حماية عمليات نقل البيانات خارج المملكة.

6.	تحديد وتقييم المخاطر	- تقييم المخاطر وتوضيح أثرها على الشخص المعني. - توضيح مصدر الخطر وطبيعة تأثيره وإحتماليته ويتضمن ذلك: - احتمالية حدوث الخطر (منخفض / محتمل / مرجح). - شدة ودرجة الخطر (طفيفة / كبيرة / شديدة). - نتيجة الخطر (منخفضة / متوسطة / مرتفعة).
7.	التدابير المتخذة للحد من المخاطر والتقليل منها	- توضيح التدابير الأمنية والتقنية والتنظيمية المتخذة للحد من المخاطر والتقليل منها والتي تم تحديد نتيجة خطرهما في المادة (6) من هذا الدليل الإرشادي، ويتضمن ذلك: - وصف طبيعة الخطر. - الخيارات التي تم إتخاذها للحد من الخطر وتقليله. - تأثير الخيارات التي تم إتخاذها على المخاطر (تم القضاء عليه - تم تقليله - تم قبوله). - المخاطر المتبقية (منخفضة / متوسطة / مرتفعة).
8.	توثيق عملية تقييم أثر حماية البيانات	- يجب توثيق عملية تقييم أثر حماية البيانات لتشمل جميع ما ذكر سابقاً. في حال عدم وجود حاجة أو ضرورة لاجراء هذا التقييم، يجب توثيق ذلك وتوضيحه، إضافة إلى: - توصية المراقب. - ملاحظات وتعليقات أصحاب المصلحة. - الموافقات التي تم اتخاذها على التدابير والتمتددة للحد من المخاطر والتقليل منها وذلك لضمان حماية البيانات. - الشخص المكلف بمراجعة التقييم ومتابعته.
9.	المراجعة والتقييم الدوري	- مراجعة تقييم أثر حماية البيانات باستمرار وبشكل دوري بالإضافة إلى مراقبة الأداء لعملية التقييم. - قد يكون هناك حاجة الى إعادة التقييم اذا جرى أي تغيير على أغراض او نطاق المعالجة.

مرفقات:

للرجوع إلى تعليمات التدابير الأمنية والتقنية والتنظيمية لسنة 2025 يرجى [الضغط هنا](#)

رقم النسخة	التاريخ	الاعداد	المراجعة	الموافقة
1				

تم اعداد هذه الوثيقة وفقا لمعايير أيزو العالمية (ISO 9001:2015 Quality Management Systems)